

MÉMOIRE DE FIN D'ÉTUDES - ENSPY
AUDIT DE SÉCURITÉ APPLICATIVE FUSIONNÉ
Méthode MUSA : Cas GIDOCEP / SOLTEC

AIDE MÉMOIRE DE MISSION

Les 5 phases d'une mission MUSA, architecture documentaire : inputs, outputs et rôle de chaque outil dans le cycle

ISO 19011:2018 | IIA Normes 2024 | Méthode MUSA (Inspirée du chapitre 7 Cours d'Audit des Systèmes d'Informations | HN3-ENSPY

Différence structurante avec un audit SI classique : la mission MUSA ne sépare pas un cycle 'audit applicatif' et un cycle 'audit sécurité', chaque phase ci-dessous produit des livrables fusionnés, exploitables en un seul passage terrain, adapté au budget d'une PME.

Phase 01 : Travaux préparatoires

01 - Travaux préparatoires		
Inputs	Activités clés	Outputs
- Documentation GIDOCEP disponible (spécifications, contrats si existants) - Organigramme simplifié SOLTEC	- Prise de connaissance de GIDOCEP - Identification des risques inhérents par domaine MUSA (A à E), sans présumer l'existence des contrôles - Collecte des documents T01-T05 et G01-G13 (Outil 3)	- Fiche technique + TDR signés (Outils 1 et 2) - Cartographie préliminaire des risques
Durée indicative : [J-xx → J-xx]		

Phase 02 : Planification

02 - Planification		
Inputs	Activités clés	Outputs
- Fiche technique et TDR validés - Cartographie préliminaire des risques	- Cotation Probabilité × Impact des risques - Construction de la matrice Domaine → Assertion → Question → PT - Finalisation du Plan d'audit (Outil 6)	- Plan d'audit validé (Outil 6) - Guide d'entretien fusionné finalisé (Outil 5) - Outil MUSA (grille O/N/PAS + entropie) initialisé
Durée indicative : [Jxx → Jxx]		

Phase 03 : Exécution (Terrain)

03 - Exécution (Terrain)		
Inputs	Activités clés	Outputs
- Plan d'audit validé - Guide d'entretien fusionné - Accès aux documents G01-G13	- Entretiens fusionnés par domaine (A à E) chaque question teste la réponse de l'AUDITÉ - Tests techniques (droits d'accès, chiffrement, configuration, logs) - Tests de restauration de sauvegarde	- Papiers de travail (PT-A à PT-E) renseignés - Outil MUSA complété : réponses O/N/PAS + entropie de Shannon par domaine
Durée indicative : [Jxx → Jxx]		

Phase 04 : Communication des résultats

04 - Communication des résultats		
Inputs	Activités clés	Outputs
- PT-A à PT-E renseignés - Outil MUSA complété	- Consolidation des constats, scoring impact/probabilité - Procédure contradictoire : envoi des constats provisoires à SOLTEC, recueil des réponses	- Rapport d'audit fusionné définitif - Plan de remédiation hiérarchisé (Quick Wins / Actions structurelles)

	• Rédaction du rapport définitif	
--	----------------------------------	--

Durée indicative : [Jxx → Jxx]

Phase 05 : Suivi (hors cycle de mémoire, à titre indicatif)

05 - Suivi des recommandations		
Inputs	Activités clés	Outputs
Plan de remédiation transmis à SOLTEC	Vérification des preuves de mise en œuvre des recommandations (si le calendrier du mémoire le permet)	État d'avancement des recommandations

Durée indicative : [M+I → M+xx]

Légende

- Outil MUSA : O = Conforme | N = Non conforme | PAS = Pas Assez Savoir (zone grise), calculé à partir des sous-réponses technique et organisationnelle OK/KO/NSP
- Entropie de Shannon H, $H < 0,5$: certitude | $0,5 \leq H < 1,0$: incertitude modérée | $H \geq 1,0$: zone grise critique nécessitant un approfondissement
- Les recommandations non levées réalimentent, le cas échéant, la Phase 1 d'un cycle suivant